



UNIVERSITATEA
LUCIAN BLAGA
— DIN SIBIU —

FACULTATEA DE
ȘTIINȚE ECONOMICE

BACHELOR THESIS
UNDERSTANDING WHAT YOU ARE CLICKING:
AUTOMATED ANALYSIS AND COMPARISON OF WEBSITE
PRIVACY POLICIES

Scientific Coordinator:

Associate Professor, Ph.D. Eduard Alexandru STOICA

Student:

MITEA Diana-Maria

Business Informatics

SIBIU 2026

Summary

The contemporary digital economy relies on continuous personal data extraction. While regulations like the General Data Protection Regulation (GDPR) mandate "Privacy by Default" and explicit consent, the practical implementation has created a deeply flawed ecosystem. Corporations frequently utilize impenetrable privacy policies and deceptive "Dark Patterns" within cookie banners, resulting in "compliance theatre"—where websites project regulatory adherence while continuing to harvest data unchecked. Currently, end-users lack tools to verify if a site's technical tracking aligns with its legally stated privacy declarations.

To address this gap, this thesis details the development and evaluation of a client-side browser extension: the *Privacy Policy Analyzer & Cookie Trax*. The application utilizes a dual-engine architecture. A Natural Language Processing (NLP) module evaluates privacy claims by parsing legal documentation to calculate a quantifiable risk score. Simultaneously, a dynamic browser storage scanner audits live tracking payloads, specifically monitoring HTTP cookies and HTML5 Web Storage APIs for pre-consent tracking violations. A discrepancy engine then cross-references these streams to detect fabricated consent architectures.

Evaluated against 15 highly trafficked global domains, the application conclusively demonstrated widespread non-compliance. Key findings include fabricated consent states where platforms pre-initialize tracking and ignore explicit opt-outs (Temu); sophisticated storage evasion bypassing standard cookie-blocking (TikTok); and unverifiable server-side processing stripping users of data autonomy (Meta, OpenAI).

Ultimately, this research proves that evaluating privacy solely through legal documentation is insufficient. Empowering users with real-time technical diagnostics is essential to neutralizing compliance theatre and enforcing verifiable digital privacy.

List of Figures and Tables

Figure 1. Aggregate distribution of privacy flags extracted across the benchmark dataset (N=15).....	11
Figure 2. Application dashboard rendering a comparative compliance analysis between a low-risk domain (down) and a high-risk domain (up)	12
Figure 3. Diagnostic view of pre-consent local storage injection, demonstrating tracking initialization prior to user authorization.....	13
Figure 4. Example of Visual Interference and obstruction utilized within a Consent Management Platform.....	14
Table 1. Benchmark Dataset of Analyzed Privacy Policies (N=15).....	8
Table 2. Automated Textual Analysis Metrics by Domain	9
Table 3. Top 5 Most Frequent Privacy Keywords Across All Domains	10
Table 4. Pre-Consent Tracking Baseline (Zero-Interaction State)	12

List of Abbreviations

- **API / APIs:** Application Programming Interface / Interfaces
- **CMPs:** Consent Management Platforms
- **CSS:** Cascading Style Sheets (used as CSS in the methodology)
- **DOM:** Document Object Model
- **DPA / DPAs:** Data Protection Authority / Data Protection Authorities
- **GDPR:** General Data Protection Regulation
- **GPC:** Global Privacy Control
- **HTML / HTML5:** HyperText Markup Language
- **HTTP:** Hypertext Transfer Protocol
- **LLM:** Large Language Model
- **NLP:** Natural Language Processing
- **PET:** Privacy-Enhancing Technology
- **Regex:** Regular Expressions
- **RTB:** Real-Time Bidding
- **SPA:** Single-Page Application
- **UI:** User Interface
- **UX:** User Experience
- **W3C:** World Wide Web Consortium

Table of Contents

Summary	2
List of Figures and Tables	3
List of Abbreviations	4
1. Introduction	1
1.1 Background and Motivation	1
1.2 Problem Statement	1
1.3 Research Objectives	1
1.4 Structure of the Thesis	2
2. Theoretical framework	3
2.1 The Regulatory Landscape of Digital Privacy	3
2.1.1 The General Data Protection Regulation (GDPR)	3
2.1.2 The ePrivacy Directive ("The Cookie Law")	3
2.2 Technical Mechanics of Digital Tracking	3
2.2.1 HTTP Cookies and Third-Party Injection	4
2.2.2 Modern Evasion: HTML5 Web Storage APIs	4
2.2.3 Stateless Tracking: Browser Fingerprinting	4
2.3 Deceptive Design and Compliance Evasion	5
2.3.1 The Taxonomy of Dark Patterns	5
2.3.2 The Phenomenon of "Compliance Theater"	5
2.4 The Role of Automated Auditing	5
3. Methodology	6
3.1 System Architecture and Design Justification	6
3.2 Contextual Keyword Extraction and Risk Tiering	6
3.3 Dynamic Cookie Analysis Integration	6
3.4 Ethical Considerations and Data Minimization in Tool Development	7
4. Results	8
4.1 Benchmark Dataset Selection	8
4.2 Textual Analysis Metrics and Risk Tiering	8
4.2.1 Aggregate Keyword Frequency and Categorical Distribution	9
4.2.2 Extraction Limitations and Architectural Edge Cases	11
4.3 Browser Cookie Detection & Baseline Auditing	11
4.4. Visual Diagnostics: The Application Interface	12
4.5 Live DOM Auditing: Capturing Evasion Tactics	13
4.6 Dark Pattern Typology in Consent Banners	13
5. Discussion	15

5.1 Synthesis of Empirical Findings	15
5.2 Architectural Evasion: The Illusion of Consent	15
5.2.1 Fabricated Consent States and Dark Patterns (Temu)	15
5.2.2 Evasive Local Storage Architectures (TikTok)	15
5.2.3 Unverifiable Architectures and Ignored Opt-Outs (Meta and OpenAI)	16
5.3 The Economic Drivers of Compliance Theatre: Real-Time Bidding (RTB)	16
5.4 Implications for Regulatory Frameworks	16
5.5 The Necessity of Automated Client-Side Auditing	16
6. Conclusions	18
6.1 Summary of Research and Findings	18
6.2 Technical Limitations of the Developed Application	18
6.3 Future Work and Research Directions	19
6.4 Final Concluding Remarks	19
References	20
Appendices	22

1. Introduction

1.1 Background and Motivation

The contemporary digital economy is fundamentally predicated on the extraction, commodification, and algorithmic analysis of personal data. In response to the ubiquitous tracking mechanisms deployed by digital platforms, international regulatory bodies have established stringent normative frameworks, most notably the European Union's General Data Protection Regulation (GDPR) and the ePrivacy Directive (European Parliament and Council of the European Union, 2002) (European Parliament and Council of the European Union, 2016). The legislative intent of these frameworks is to enforce the principle of "Privacy by Design and by Default," mandating corporate transparency, data minimization, and the necessity of acquiring explicit, informed user consent prior to the initialization of non-essential tracking technologies.

As a direct consequence of these regulatory mandates, digital interfaces have been structurally transformed by the integration of mandatory privacy policies and cookie consent banners. Theoretically, these consent management platforms (CMPs) dismantle the information asymmetry between corporations and consumers, empowering users to govern their digital footprints. However, the practical implementation of these compliance mechanisms has precipitated a highly flawed, and often deceptive, privacy ecosystem.

1.2 Problem Statement

Despite robust legislative efforts, a significant operational discrepancy exists between regulatory mandates and corporate technical compliance. This persistent gap manifests through two primary vectors of user disenfranchisement:

Firstly, written privacy policies induce severe information friction. They are drafted as exhaustive legal instruments, often spanning tens of thousands of words, rendering them functionally inaccessible to the average user (Wilson, et al., 2016). Consequently, individuals cannot practically audit the data collection, third-party sharing, and retention practices of the vast array of domains they interact with daily.

Secondly, the technical execution of consent architectures frequently violates the core tenets of the GDPR through a phenomenon known as "compliance theater." Corporations systematically utilize "Dark Patterns"—manipulative user interface (UI) designs—to obfuscate opt-out mechanisms and coerce consent (Gray, et al., 2018) (Nouwens, et al., 2020). Furthermore, empirical evidence suggests a disconnect between the UI and the underlying browser Document Object Model (DOM); websites frequently initiate tracking payloads prior to consent (violating default privacy) or ignore explicit user rejections entirely (Matte, et al., 2020). Currently, end-users lack accessible, real-time diagnostic tools capable of verifying whether a domain's technical tracking behavior securely aligns with its legally stated privacy declarations (Zaeem, et al., 2020).

1.3 Research Objectives

The central objective of this thesis is to bridge the systemic gap between theoretical privacy claims and actual technical execution. To achieve this, the research details the architectural design, algorithmic development, and empirical evaluation of a privacy-preserving, client-side browser extension (Privacy Policy Analyzer & Cookie Trax).

The specific, measurable objectives of this research are:

- Automated Static Analysis: To engineer a lightweight, client-side Natural Language Processing (NLP) algorithm capable of instantaneously parsing complex privacy

documentation, classifying risk vectors (e.g., third-party data brokering), and outputting a quantifiable privacy risk metric.

- **Dynamic Storage Auditing:** To develop a real-time browser storage scanner capable of detecting traditional HTTP cookies alongside evasive local storage architectures (e.g., localStorage), specifically auditing for pre-consent tracking violations.
- **Discrepancy Engine Implementation:** To design a cross-referencing module that evaluates the logical consistency between a domain's theoretical policy claims, its consent banner interface, and its live tracking payload, explicitly flagging ignored opt-outs.
- **Empirical Evaluation:** To deploy the developed application against a benchmark dataset of highly trafficked global domains, providing a data-driven assessment of the current state of digital privacy compliance.

1.4 Structure of the Thesis

This thesis is organized into six core chapters to systematically address the research objectives. Following this introduction, Chapter 2 (Theoretical Framework) provides a comprehensive review of the legal foundations of the GDPR, the technical mechanics of web tracking, and the taxonomy of Dark Patterns. Chapter 3 (Methodology) delineates the software architecture of the application, justifying the implementation of a client-side JavaScript engine within the Manifest V3 framework. Chapter 4 (Results) presents the quantitative data and baseline metrics gathered from evaluating the benchmark dataset. Chapter 5 (Discussions) interprets these empirical findings, utilizing specific architectural case studies to demonstrate the pervasive nature of fabricated consent. Finally, Chapter 6 (Conclusions) synthesizes the research outcomes, delineates the technical limitations of the application, and proposes avenues for future development.

2.Theoretical framework

This chapter establishes the theoretical and technical foundation upon which the empirical research is built. It examines the contemporary regulatory landscape governing digital privacy, dissects the underlying web technologies utilized for data extraction, and explores the systemic use of deceptive user interface designs that circumvent legal compliance.

2.1 The Regulatory Landscape of Digital Privacy

The exponential growth of the data brokerage industry has necessitated the creation of robust legal frameworks designed to protect consumer privacy. In the European Union, this is primarily governed by two overlapping legislative instruments: the General Data Protection Regulation (GDPR) and the ePrivacy Directive.

2.1.1 The General Data Protection Regulation (GDPR)

Enacted in 2018, the GDPR represents the most comprehensive data protection law globally (European Parliament and Council of the European Union, 2016). It operationalizes privacy not merely as a consumer preference, but as a fundamental human right. For the context of this research, several core tenets of the GDPR are highly relevant:

- **Transparency and Information Asymmetry:** Article 12 mandates that corporate privacy policies must be concise, transparent, intelligible, and easily accessible. The persistent use of complex legal jargon in privacy documentation is fundamentally at odds with this requirement.
- **Conditions for Consent:** Article 7 dictates that consent must be freely given, specific, informed, and unambiguous. Crucially, the law stipulates that withdrawing consent must be as easy as granting it—a requirement frequently violated in modern web architectures.
- **Privacy by Design and by Default:** Article 25 requires data controllers to implement technical measures that ensure, by default, only personal data strictly necessary for a specific purpose is processed. This establishes the legal baseline that no non-essential tracking mechanisms should be active prior to explicit user authorization.

2.1.2 The ePrivacy Directive ("The Cookie Law")

While the GDPR governs personal data broadly, the ePrivacy Directive specifically regulates electronic communications and the use of tracking technologies. It requires explicit prior consent before any website can read or write information (such as cookies) to a user's terminal equipment, excepting strictly necessary functional processes (European Parliament and Council of the European Union, 2002). Together, the GDPR and the ePrivacy Directive mandate the implementation of Consent Management Platforms (CMPs)—commonly known as cookie banners.

2.2 Technical Mechanics of Digital Tracking

To analyse compliance discrepancies, it is essential to understand the technical architecture of digital tracking. The web operates on the Hypertext Transfer Protocol (HTTP), which is inherently "stateless"—meaning the server retains no memory of previous user interactions. To maintain state (e.g., keeping a user logged in), developers utilize browser storage application programming interfaces (APIs).

2.2.1 HTTP Cookies and Third-Party Injection

Cookies are small, stateful text files injected into the browser's memory by a web server (Barth, 2011). They are categorized by provenance and duration:

- **First-Party vs. Third-Party:** First-party cookies are set by the host domain (e.g., temu.com) primarily for functional purposes. Third-party cookies are injected by external domains (e.g., google-analytics.com OR facebook.com) embedded within the host's source code, acting as cross-site surveillance vectors (Englehardt & Narayanan, 2016).
- **Session vs. Persistent:** Session cookies are ephemeral and delete upon browser closure. Persistent cookies are engineered with distant expiration dates (often exceeding a year), enabling longitudinal profiling of user behaviour across the internet.

2.2.2 Modern Evasion: HTML5 Web Storage APIs

As browser vendors (such as Apple's Safari and Mozilla's Firefox) began automatically blocking third-party HTTP cookies to enhance user privacy, data aggregators evolved their methodologies. Modern platforms frequently bypass standard HTTP cookies entirely, utilizing HTML5 Web Storage APIs (localStorage and sessionStorage) (World Wide Web Consortium, 2016).

Unlike cookies, which are automatically attached to HTTP requests, data in localStorage is explicitly queried and manipulated via client-side JavaScript. This architecture allows developers to store vast amounts of tracking identifiers locally, often evading rudimentary cookie-blocking extensions and legacy compliance audits (Al-Rousan, et al., 2019) (Rodriguez & Posegga, 2018).

2.2.3 Stateless Tracking: Browser Fingerprinting

While HTTP cookies and HTML5 Web Storage represent stateful tracking mechanisms—meaning they actively store data on the user's terminal equipment—the digital advertising ecosystem is increasingly migrating toward "stateless" tracking techniques to evade regulatory scrutiny. The most prominent of these methods is browser fingerprinting.

Unlike traditional cookies, fingerprinting does not require the website to store a text file on the user's device. Instead, the website utilizes background JavaScript to quietly query the user's browser for hundreds of specific configuration details (Mowery & Shacham, 2012). These data points include the device's operating system, screen resolution, installed system fonts, time zone, language preferences, and even the specific rendering characteristics of the device's graphics card (Canvas fingerprinting).

When these seemingly innocuous data points are combined, they create a unique cryptographic hash—a "fingerprint"—that identifies the individual user with an accuracy rate frequently exceeding 99%. Because fingerprinting relies on the inherent characteristics of the device rather than injected files, it completely bypasses traditional cookie-blocking extensions and local storage audits. From a regulatory perspective under the GDPR, fingerprinting is highly problematic; it operates invisibly, offers no technical mechanism for the user to delete or "clear" the tracker, and makes verifying consent practically impossible. While the current iteration of the Privacy Policy Analyzer & Cookie Trax focuses on stateful storage APIs, acknowledging the rise of stateless fingerprinting is essential for understanding the full spectrum of technical evasion strategies deployed by modern domains.

2.3 Deceptive Design and Compliance Evasion

The mandate to obtain explicit consent disrupted the default data-harvesting model of the digital economy. In response, the industry widely adopted adversarial UI/UX strategies to maintain high opt-in rates, a practice technically defined as "Deceptive Design" or "Dark Patterns."

2.3.1 The Taxonomy of Dark Patterns

Dark Patterns are user interfaces meticulously engineered to subvert user autonomy, exploiting cognitive biases to secure consent (Gray, et al., 2018) (Kocyigit, et al., 2023). Common manifestations within Consent Management Platforms include:

- **Visual Interference:** Highlighting the "Accept All" button with vibrant, contrasting colours while rendering the "Decline" or "Manage Settings" options as muted, low-contrast text (Soe, et al., 2020).
- **Click Fatigue (Obstruction):** Allowing users to accept all tracking with a single click, but requiring them to navigate through multiple nested menus to reject the same tracking.
- **Confirm shaming:** Utilizing emotionally manipulative language to guilt the user into accepting data extraction.
-

2.3.2 The Phenomenon of "Compliance Theater"

Beyond superficial UI manipulation, a more severe technical violation exists: compliance theatre. This occurs when a Consent Management Platform presents a legally compliant interface (e.g., offering "Accept" and "Decline" buttons) but is structurally disconnected from the website's execution logic.

In these architectures, the CMP functions merely as a visual placebo. Empirical research demonstrates that platforms engaging in compliance theatre will either execute tracking payloads synchronously with the initial page load (violating Privacy by Default) or maintain active tracking threads even after the user explicitly triggers an opt-out event (Trevisan, et al., 2019) (Utz, et al., 2019).

2.4 The Role of Automated Auditing

The confluence of verbose privacy documentation and deceptive tracking architectures has created an insurmountable burden for the individual internet user. Manual verification of corporate compliance requires advanced legal literacy combined with deep technical expertise in web development and browser console analysis.

This systemic imbalance necessitates the development of localized, automated auditing tools. By leveraging Natural Language Processing (NLP) to parse semantic legal text, and dynamic browser API monitoring to audit live DOM events, client-side software can restore transparency. Such applications evaluate both theoretical compliance (textual policy analysis) and empirical execution (cookie and storage tracking), effectively neutralizing the phenomenon of compliance theatre.

3. Methodology

3.1 System Architecture and Design Justification

To address the research objective of providing users with real-time, automated analysis of website privacy policies, a localized client-side architecture was developed. The application is built as a browser extension adhering to Manifest V3 standards, utilizing HTML, CSS, and vanilla JavaScript (Google, 2026) (Ling, et al., 2022).

The natural language processing and core analysis rely on a dedicated client-side JavaScript engine (`analyzer.js`) executing entirely within the browser. This architectural decision is justified by two primary factors:

1. **Data Privacy and Security:** Processing the policy text and scanning cookies locally ensures that the user's browsing data is never transmitted to an external server (Sanchez-Rola, et al., 2017). This approach natively aligns with the core privacy-centric ethos of the application.
2. **Performance and Scalability:** By utilizing the client's local processing power, specifically through the implementation of Web Workers (`analyzer-worker.js`), the application can asynchronously process large text files (upwards of 100,000 characters) in segmented chunks (Castro, 2021). This prevents browser interface freezing, eliminates network latency, and avoids external server hosting dependencies.

3.2 Contextual Keyword Extraction and Risk Tiering

The core text analysis relies on a custom, rule-based algorithmic engine rather than basic string matching, which is prone to false positives (Adhikari, et al., 2025). The methodology involves tokenizing the extracted privacy policy into individual sentences and analyzing them within a localized context window (evaluating the target sentence alongside its immediate preceding and succeeding sentences).

The text is scanned using Regular Expressions (Regex) against a predefined dictionary of privacy-related terms. To provide a nuanced assessment, the methodology categorizes these terms into three distinct confidence tiers: *Critical*, *Moderate*, and *Weak*. Furthermore, the algorithm applies contextual awareness by checking for:

- **Negation:** The presence of words like "not" or "never" within the context window neutralizes penalty scores for specific keywords (e.g., "we do not sell data").
- **Collection Type:** The algorithm distinguishes between mandatory data collection (e.g., "we require") and optional data collection (e.g., "you may choose"), weighting them differently in the final mathematical privacy score.

3.3 Dynamic Cookie Analysis Integration

To verify the claims made within the text of a privacy policy, a secondary methodology was employed to analyse the actual tracking behaviour of the website. The application utilizes the Chrome Cookies API to extract all active cookies associated with the current domain.

A dedicated module (`cookie-analyzer.js`) compares the names and domains of these cookies against a database of known tracker patterns. The cookies are then algorithmically sorted into five functional categories: Tracking, Analytics, Advertising, Functional, and Social. The methodology includes a discrepancy engine that cross-references the cookie findings with the text analysis. For example, if advertising cookies are detected by the API, but the text analyser finds no mention of third-party sharing in the policy, the system flags this as a high-severity privacy risk.

3.4 Ethical Considerations and Data Minimization in Tool Development

In developing a Privacy-Enhancing Technology (PET) designed to audit corporate data practices, it was a fundamental requirement that the application itself did not inadvertently introduce new privacy vulnerabilities. Traditional web auditing tools and commercially available browser extensions often rely on cloud-based processing architectures, where the user's browsing history or the targeted website's Document Object Model (DOM) is transmitted to a remote server for analysis.

To ensure strict adherence to the GDPR's principle of Data Minimization, the Privacy Policy Analyzer & Cookie Trax was engineered entirely as a localized, zero-trust system (European Parliament and Council of the European Union, 2016). By executing the Natural Language Processing (NLP) ruleset and the dynamic cookie auditing module strictly within the browser's local Web Workers, the application guarantees that no telemetry data, browsing habits, or user IP addresses are ever transmitted to an external server. This architectural decision demonstrates that high-level algorithmic auditing can be achieved without compromising the end-user's anonymity, establishing a critical baseline for ethical software development in the field of Business Informatics.

4. Results

4.1 Benchmark Dataset Selection

To systematically evaluate the effectiveness, scalability, and accuracy of the application, a benchmark dataset of website policies was established. The selected sample (N=15) comprises highly trafficked domains across diverse global sectors. This diversity is crucial for testing the application against various regulatory environments, corporate transparency standards, and web development architectures.

The dataset includes domains from technology and artificial intelligence (Microsoft, Google, OpenAI, Anthropic), social media (Meta, LinkedIn, TikTok), e-commerce (Temu, Amazon Jobs, Shein), information and media (Wikimedia, The New York Times), design software (Canva), and government (USA.gov).

Table 1 details the dataset utilized for the primary textual analysis, including the industry sector and the raw character length of the extracted privacy policy text. The variation in text length—ranging from just 185 characters (Samsung) to 78,366 characters (The New York Times)—provided a robust stress test of the application's asynchronous processing and chunking capabilities via Web Workers.

Table 1. Benchmark Dataset of Analyzed Privacy Policies (N=15)

Domain Name	Industry Sector	Policy Length (Characters)
help.nytimes.com	Media / News	78,366
policies.google.com	Technology / Search	64,205
www.canva.com	Software / Design	63,962
www.temu.com	E-commerce	60,727
foundation.wikimedia.org	Information / Non-Profit	42,632
www.linkedin.com	Social Media / Professional	41,565
www.meta.com	Social Media	40,816
www.anthropic.com	Technology / AI	34,632
www.microsoft.com	Technology / Software	31,040
openai.com	Technology / AI	28,747
www.tiktok.com	Social Media	28,174
www.sheingroup.com	E-commerce	24,121
www.amazon.jobs	E-commerce / Corporate	9,510
www.usa.gov	Government	4,400
privacy.samsung.com	Technology / Electronics	185

Source: Author's own research based on application data extraction.

4.2 Textual Analysis Metrics and Risk Tiering

The primary objective of the application's static analysis module is to quantify the privacy risk inherent in a given policy text. The client-side NLP engine evaluated the benchmark dataset by scanning for categorized keywords (Data Collection, Third-Party Sharing, User Rights, Data Retention, and Consent Requirement). To prevent false positives, the algorithm

processed these keywords through a contextual negation engine, calculating a final Privacy Score on a scale of 1 to 10. A score of 10 represents optimal, transparent privacy practices, while a score of 1 indicates severe privacy risks characterized by heavy data collection and minimal user rights.

Table 2 illustrates the quantitative metrics generated by the text analysis engine for all 15 domains.

Table 2. Automated Textual Analysis Metrics by Domain

Domain	Data Collection Flags	Third-Party Sharing Flags	User Rights Flags	Final Privacy Score
www.usa.gov	3	2	4	10 / 10
foundation.wikimedia.org	22	27	60	10 / 10
www.microsoft.com	33	23	64	10 / 10
openai.com	25	27	54	10 / 10
www.anthropic.com	21	39	68	10 / 10
www.canva.com	61	67	117	10 / 10
www.amazon.jobs	3	11	18	10 / 10
www.temu.com	100	84	114	10 / 10
www.sheingroup.com	27	24	60	10 / 10
privacy.samsung.com	1	0	0	10 / 10
help.nytimes.com	82	132	142	9 / 10
policies.google.com	110	69	109	8 / 10
www.tiktok.com	46	43	41	6 / 10
www.meta.com	78	66	45	1 / 10
www.usa.gov	3	2	4	10 / 10

Source. Author's own research.

The dataset reveals several distinct patterns in digital privacy documentation. Meta (www.meta.com) was identified as the highest-risk policy in the dataset, scoring 1/10. This assessment was driven by a disproportionately high volume of data collection flags (78 occurrences) and third-party sharing flags (66 occurrences) relative to a low emphasis on user rights (45 occurrences).

Conversely, media websites such as The New York Times (help.nytimes.com) generated the absolute highest volume of Third-Party Sharing flags in the entire dataset (132 occurrences). However, the algorithmic engine dynamically balanced the final score to a 9/10 because the policy heavily emphasizes User Rights (142 flags), utilizing "optional" contextual keywords rather than "mandatory" ones. This demonstrates the engine's ability to evaluate the context of data usage rather than relying purely on frequency.

4.2.1 Aggregate Keyword Frequency and Categorical Distribution

Beyond individual policy scores, the application provided a macro-level view of industry-standard terminology. Across all 15 domains, the algorithm processed thousands of individual sentences. A frequency distribution analysis reveals that "Data Collection" and

"User Rights" are the most heavily documented categories, highlighting the tension between corporate data harvesting and GDPR-mandated disclosures.

Beyond individual policy scores, the application provided a macro-level view of industry-standard terminology. Across all 15 domains, the algorithm processed thousands of individual sentences. A frequency distribution analysis reveals that "Data Collection" and "User Rights" are the most heavily documented categories, highlighting the tension between corporate data harvesting and GDPR-mandated disclosures.

Table 3. Top 5 Most Frequent Privacy Keywords Across All Domains

Rank	Keyword / Phrase	Category	Total Occurrences	Implication
1	"Collect"	Data Collection	283	Indicates ubiquitous, proactive data harvesting across all sectors.
2	"Share"	Third-Party Sharing	212	Highlights the highly interconnected nature of digital data brokering.
3	"Access"	User Rights	200	Reflects standardized compliance language required by GDPR (Right to Access).
4	"Consent"	User Rights / Consent	179	Utilized to establish a legal basis for processing user data.
5	"Location"	Data Collection	68	Demonstrates a high demand for geospatial tracking, particularly in tech and social media.

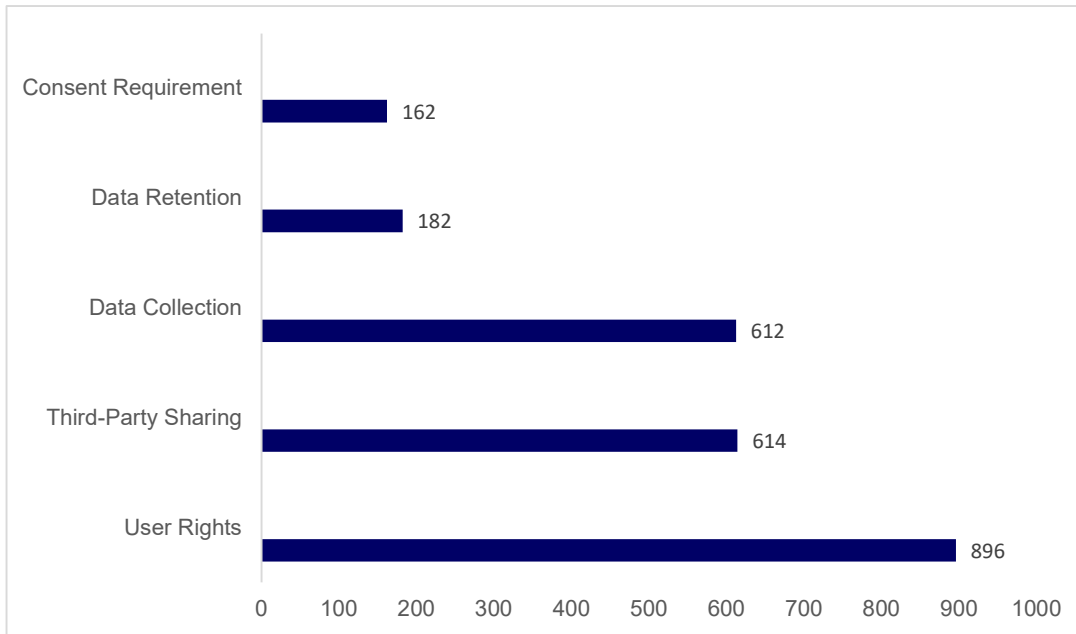


Figure 1. Aggregate distribution of privacy flags extracted across the benchmark dataset (N=15).

4.2.2 Extraction Limitations and Architectural Edge Cases

The testing process also highlighted a structural limitation in automated text extraction. The policy for Samsung (privacy.samsung.com) yielded only 185 characters, triggering a single data collection flag and resulting in an artificially perfect score of 10/10. This anomaly occurs when websites employ strict "Cookie Walls" or rely heavily on dynamic client-side rendering frameworks (e.g., React or Angular) where the policy text is not immediately available in the HTML Document Object Model (DOM) upon initial page load. This edge case proves that while the contextual NLP algorithm is highly accurate, pure textual analysis is insufficient for a complete privacy audit, necessitating the secondary dynamic cookie analysis module.

4.3 Browser Cookie Detection & Baseline Auditing

While textual analysis provides a theoretical assessment of a company's privacy stance, the application's dynamic module (cookie-analyzer.js) evaluates real-world tracking behaviour. To test adherence to the "Privacy by Default" principle mandated by frameworks like the ePrivacy Directive and the GDPR, a strict pre-consent testing protocol was established.

The application scanned a subset of the benchmark domains in a clean, isolated, and incognito browser session before any user interaction with the mandatory cookie consent banner occurred. Under strict interpretations of European privacy law, this pre-consent state should yield zero non-essential tracking, analytics, or advertising cookies.

Table 4 details the findings of this pre-consent baseline audit. The data definitively proves a widespread failure to comply with "Privacy by Default" regulations.

Table 4. Pre-Consent Tracking Baseline (Zero-Interaction State)

Domain	Consent Banner Active?	Total Trackers Found	High-Risk Trackers	Pre-Consent Privacy Score
www.facebook.com	Yes	1	1 (Social/Tracking)	82 / 100
openai.com	Yes	4	4 (Analytics/Social)	81 / 100
www.tiktok.com	Yes	52	44 (Social/Tracking)	30 / 100
www.temu.com	Yes	14	8 (Tracking/Ads)	27 / 100

Source: Dynamic auditing via the Cookie Trax application.

As demonstrated in Table 4, all tested domains-initiated tracking payloads prior to user approval, indicating systemic non-compliance with default privacy standards.

4.4. Visual Diagnostics: The Application Interface

To effectively bridge the gap between complex legal documentation and user comprehension, the Privacy Policy Analyzer & Cookie Trax was designed with a traffic-light-inspired, risk-tiering graphical user interface (GUI). The empirical results of the NLP scoring and the dynamic cookie auditing are aggregated and presented to the end-user via the extension's popup dashboard.

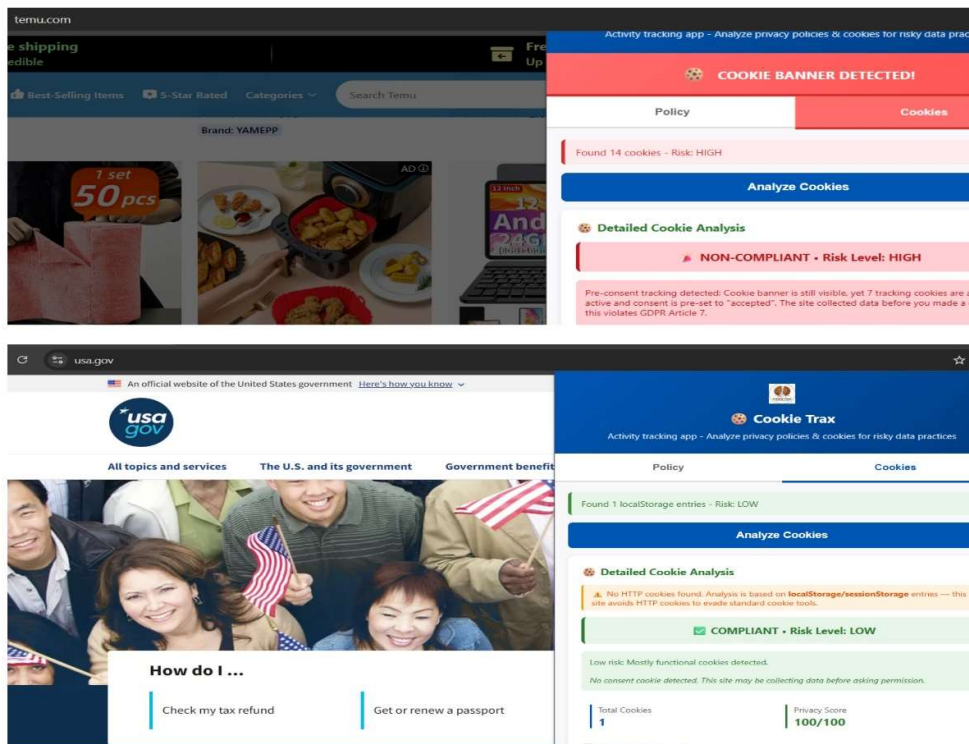


Figure 2. Application dashboard rendering a comparative compliance analysis between a low-risk domain (down) and a high-risk domain (up)

As illustrated in Figure 2, the interface immediately alerts the user to the underlying technical reality of the domain. By visualizing the discrepancy between the stated privacy score and the live tracking payload, the application successfully neutralizes the information friction caused by verbose legal texts.

4.5 Live DOM Auditing: Capturing Evasion Tactics

A critical component of the results was demonstrating the application's ability to detect evasive tracking architectures, specifically pre-consent local storage injections. To prove the existence of "compliance theatre," the application's background scripts logged the exact moment tracking payloads bypassed the Consent Management Platform (CMP).

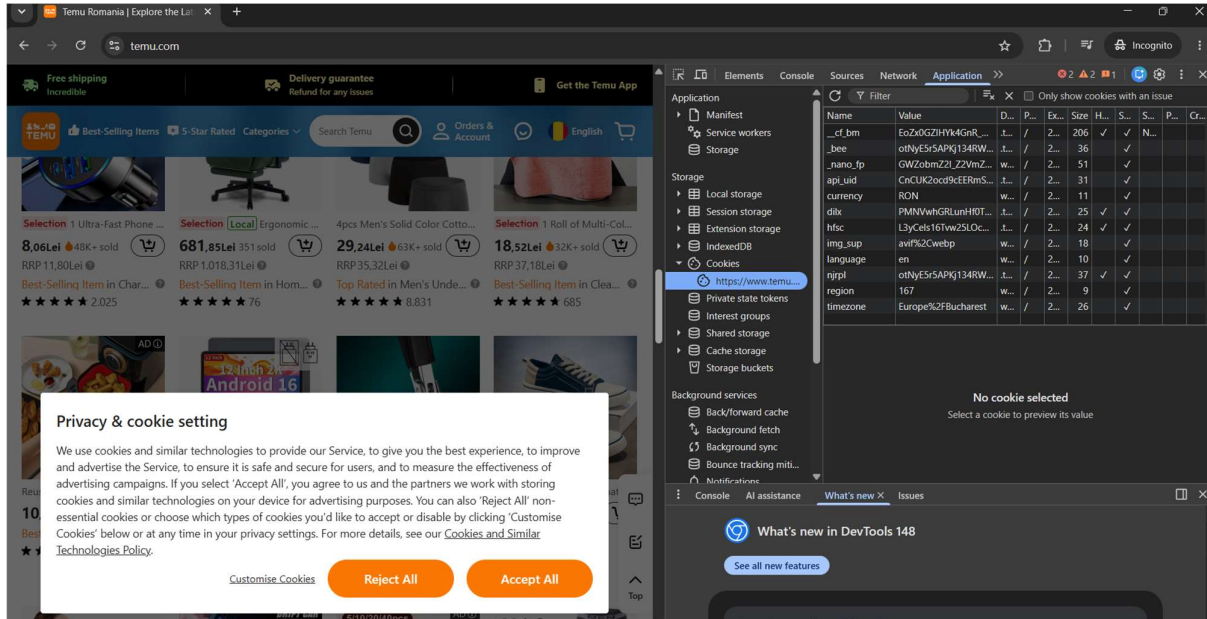


Figure 3. Diagnostic view of pre-consent local storage injection, demonstrating tracking initialization prior to user authorization.

Figure 3 provides empirical proof of the compliance evasion detailed in Chapter 2. While the user interface displays a pending consent state, the underlying Document Object Model (DOM) and storage APIs have already been compromised. The application's ability to expose these hidden payloads in real-time validates the necessity of client-side dynamic auditing over traditional, manual policy reviews.

4.6 Dark Pattern Typology in Consent Banners

In addition to automated technical auditing, a manual visual analysis of the benchmark dataset's consent banners was conducted to categorize the deceptive design strategies utilized to secure data extraction. The most prevalent Dark Pattern identified across the 15 domains was Visual Interference, combined with Click Fatigue.

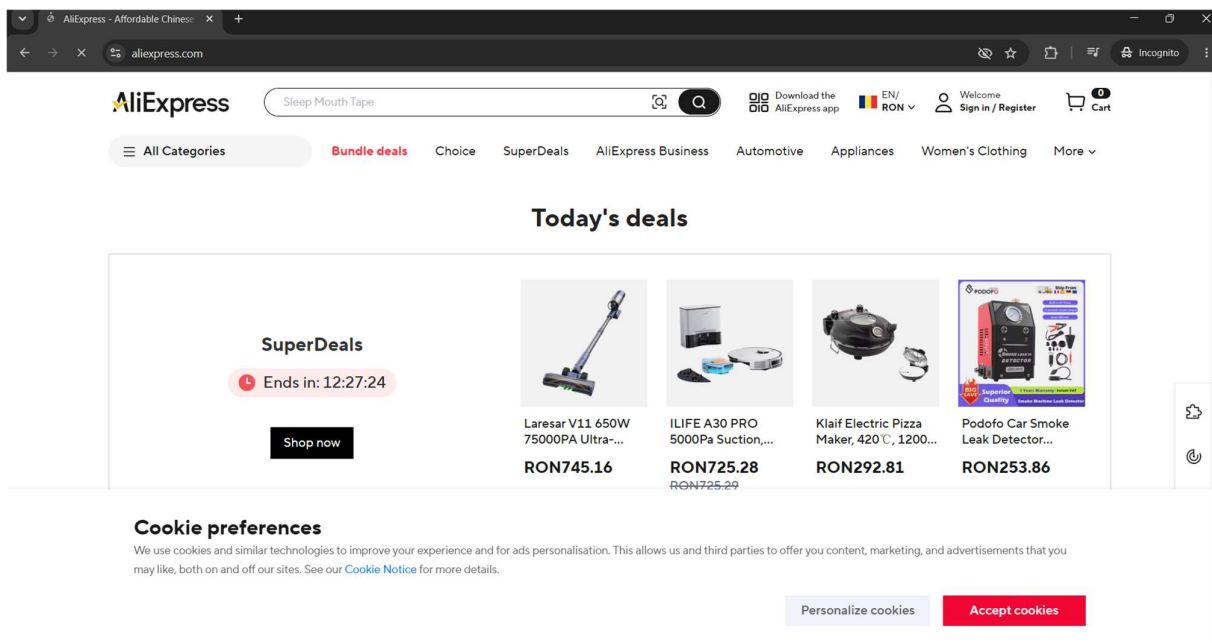


Figure 4. Example of Visual Interference and obstruction utilized within a Consent Management Platform.

As demonstrated in the architecture captured in Figure 4, corporations heavily manipulate contrast ratios and visual hierarchy to coerce affirmative actions. The asymmetry in the effort required to reject tracking versus accepting it constitutes a direct violation of the GDPR's mandate for freely given and easily withdrawable consent.

5. Discussion

5.1 Synthesis of Empirical Findings

The empirical data gathered through the Privacy Policy Analyzer & Cookie Trax application reveals a profound systemic fracture between written regulatory compliance and technical execution. While the static textual analysis (Chapter 4.2) demonstrated that corporations are highly proficient at generating GDPR-compliant legal documentation—frequently emphasizing "User Rights" and "Transparency"—the dynamic browser auditing (Chapter 4.3) proved these claims are frequently performative.

The core finding of this research is that the digital ecosystem is currently saturated with "compliance theater." Consent Management Platforms (CMPs), rather than acting as genuine gateways for user autonomy, are systematically weaponized as UI friction points designed to secure data extraction while providing an illusion of legal adherence (Utz, et al., 2019) (see Figure 4 for an example of this UI friction). This phenomenon is best illustrated by dissecting the architectural edge cases discovered during the dynamic auditing phase.

5.2 Architectural Evasion: The Illusion of Consent

By cross-referencing the state of the user interface (the consent banner) with the live Document Object Model (DOM) and browser storage APIs, the application's discrepancy engine identified three distinct technical strategies utilized by domains to circumvent user privacy controls.

5.2.1 Fabricated Consent States and Dark Patterns (Temu)

The audit of the e-commerce platform Temu (www temu.com) provides a definitive example of deceptive UI design overriding user intent. The application identified 14 active tracking cookies injected pre-consent. More critically, the discrepancy engine detected that the internal HTTP consent record (`privacy_setting_detail`) was pre-initialized to an "Accepted" state before the user interacted with the page (as visualized in the DOM diagnostic in Figure 3).

When the "Reject All" pathway was explicitly triggered, the platform maintained all 14 tracking cookies and refused to alter the `privacy_setting_detail` variable. From a Business Informatics perspective, this represents a deliberate architectural choice. The banner is decoupled from the data collection pipeline; it exists solely to simulate compliance for rudimentary regulatory audits, while the underlying technical architecture is optimized entirely for continuous data harvesting, directly violating GDPR Article 7.

5.2.2 Evasive Local Storage Architectures (TikTok)

The evaluation of TikTok (www.tiktok.com) highlights the ongoing technical "arms race" between privacy regulations and data aggregators. As browsers increasingly block third-party HTTP cookies by default, sophisticated platforms migrate their tracking vectors to HTML5 Web Storage APIs (`localStorage` and `sessionStorage`).

The application detected that TikTok bypasses traditional HTTP cookies almost entirely, initializing 52 local storage tracking entries pre-consent (Urban, et al., 2020). Furthermore, explicitly declining consent resulted in a nearly identical payload (57 active entries). This architectural shift demonstrates that legacy compliance tools—which predominantly scan for HTTP cookies—are no longer sufficient. By utilizing local storage, TikTok successfully obfuscates its tracking payload from standard regulatory scrutiny while maintaining a continuous stream of user behavioral data.

5.2.3 Unverifiable Architectures and Ignored Opt-Outs (Meta and OpenAI)

The audits of Meta and OpenAI revealed a more subtle, yet equally non-compliant, strategy: the complete disregard of opt-out signals coupled with unverifiable server-side architectures. In both instances, explicitly declining optional tracking failed to terminate the active tracking payloads (1 persistent cookie for Meta; 4 analytics entries for OpenAI).

Furthermore, the application flagged these environments as utilizing "Unverifiable Consent." When a user interacted with the CMP, no corresponding state change was recorded in the client-side HTTP headers or local storage. This implies that consent states are processed entirely server-side. This opaque architecture strips the user of any ability to independently verify if their data rights are being honored, contradicting the fundamental GDPR principle of transparent processing.

5.3 The Economic Drivers of Compliance Theatre: Real-Time Bidding (RTB)

To fully comprehend the persistent and systemic nature of the compliance theatre identified by the discrepancy engine, one must analyze the underlying economic incentives driving these architectural decisions. The modern digital ecosystem is financially sustained by Real-Time Bidding (RTB) networks—automated algorithmic auctions where user data is broadcasted and sold to thousands of advertisers in the milliseconds it takes a webpage to load (Veale & Zuiderveen Borgesius, 2022).

The domains evaluated in this dataset (e.g., Meta, TikTok, Temu) do not implement Dark Patterns or evasive local storage architectures out of poor software engineering; rather, these are deliberate, profit-maximizing strategies. "Privacy by Default" poses an existential threat to the RTB revenue model. If a platform strictly adheres to the GDPR and waits for explicit, informed consent before initializing tracking payloads, the platform forfeits the ability to monetize the user's initial page view.

Therefore, pre-initializing tracking payloads (as seen in the Temu case study) and fabricating consent states are calculated business risks. Corporations weigh the financial benefits of uninterrupted data harvesting against the relatively low probability of a manual technical audit by an under-resourced Data Protection Authority (DPA). The widespread non-compliance observed in the baseline auditing phase is a direct reflection of an industry prioritizing the lucrative demands of the algorithmic ad-exchange over the fundamental digital rights of the consumer. Understanding this economic reality highlights why technical constraints, rather than legal threats alone, are necessary to enforce compliance.

5.4 Implications for Regulatory Frameworks

The findings of this thesis have significant implications for the future of digital privacy legislation. The data proves that relying on corporate self-reporting and the mandatory display of privacy policies is a failed regulatory paradigm (Klonick, 2025). The GDPR and the ePrivacy Directive have successfully forced companies to display banners, but they have largely failed to alter the underlying technical infrastructure of data extraction.

This resulting "compliance theater" places an impossible burden on the individual. Users are experiencing severe consent fatigue, conditioned to click "Accept All" to access content, unaware that clicking "Reject" frequently yields the exact same technical outcome. The legal framework relies on the assumption that CMPs are mechanically connected to data pipelines; this research empirically proves that this assumption is critically flawed.

5.5 The Necessity of Automated Client-Side Auditing

From a software engineering and informatics standpoint, the discrepancies uncovered in this study validate the necessity of the developed application. Currently, regulatory

enforcement is reactive, relying on slow, manual audits by Data Protection Authorities (DPAs).

To restore the balance of power, the enforcement of privacy must shift from theoretical legal compliance to verifiable technical compliance. Tools like the Privacy Policy Analyzer & Cookie Trax empower users and independent researchers by providing real-time, client-side diagnostics. By automating the cross-referencing of NLP-parsed policy claims against dynamic browser storage events, end-users can instantly detect Dark Patterns, fabricated consent states, and evasive architectures, effectively neutralizing the corporate reliance on compliance theater.

6. Conclusions

6.1 Summary of Research and Findings

The primary objective of this thesis was to investigate and expose the systemic discrepancy between written regulatory compliance and actual technical execution within the digital privacy ecosystem. To achieve this, a localized, client-side browser application (Privacy Policy Analyzer & Cookie Trax) was designed, developed, and empirically tested against a benchmark dataset of highly trafficked global domains.

The research successfully operationalized a dual-engine architecture: a static Natural Language Processing (NLP) module to evaluate theoretical privacy claims, and a dynamic browser storage scanner to audit live tracking payloads. By cross-referencing these two data streams, the application effectively functioned as an automated, real-time compliance auditor.

The empirical findings of this study conclusively demonstrate that the modern web is heavily reliant on "compliance theatre." Despite the stringent mandates of the General Data Protection Regulation (GDPR) and the privacy Directive, the implementation of Consent Management Platforms (CMPs) frequently serves to obfuscate, rather than illuminate, corporate data practices.

The application successfully uncovered critical architectural violations, including:

- **Fabricated Consent States:** Domains such as Temu actively inject tracking payloads prior to user interaction and pre-set internal HTTP consent records to "Accepted," completely ignoring explicit user opt-out commands.
- **Storage Evasion:** Platforms like TikTok increasingly bypass traditional, easily auditable HTTP cookies in favour of HTML5 Web Storage APIs (localStorage), maintaining identical tracking payloads regardless of the user's consent choice.
- **Unverifiable Server-Side Processing:** Major entities like Meta and OpenAI fail to provide client-side verification of consent states, creating an opaque architecture that disregards explicit rejections and violates the GDPR's transparency mandates.

Ultimately, this thesis proves that evaluating digital privacy solely through the lens of legal documentation is insufficient. The developed application demonstrates that client-side, technical auditing is a viable and necessary mechanism to empower internet users and enforce genuine data autonomy.

6.2 Technical Limitations of the Developed Application

While the Privacy Policy Analyzer & Cookie Trax application successfully identified major compliance violations, it is subject to specific technical limitations inherent to client-side browser extensions. Acknowledging these constraints is crucial for understanding the scope of the empirical findings.

Firstly, the static textual analysis relies on a contextual, keyword-based NLP algorithm. While highly optimized for speed and client-side execution, it lacks the deep semantic understanding of a Large Language Model (LLM). Consequently, it may struggle with highly nuanced legal phrasing or atypical policy structures. Furthermore, as demonstrated by the Samsung anomaly in Chapter 4, the extraction engine cannot evaluate policies hidden behind strict "Cookie Walls" or heavily obfuscated within dynamic Single-Page Application (SPA) rendering frameworks (e.g., React) where the text is not immediately present in the initial Document Object Model (DOM).

Secondly, the dynamic storage auditing module is restricted by the browser's sandbox environment. While it successfully monitors HTTP cookies and HTML5 local storage, it cannot detect server-side tracking mechanisms. Technologies such as Server-to-Server API

tracking (e.g., the Meta Conversions API) bypass the client entirely, meaning data extracted via these methods remains invisible to the application's discrepancy engine.

6.3 Future Work and Research Directions

The limitations of the current architecture provide clear vectors for future development and academic research in the field of Business Informatics. Future iterations of the application could be enhanced in the following ways:

- **Integration of On-Device Machine Learning:** The static text analyser could be upgraded by integrating lightweight, on-device Large Language Models (utilizing WebGPU technologies). This would allow the application to perform deep semantic reasoning on privacy policies without compromising user privacy by sending the text to an external cloud server.
- **Automated Regulatory Reporting:** The application could be expanded to include a crowd-sourced telemetry database. When the discrepancy engine detects severe GDPR violations (such as pre-consent tracking or ignored opt-outs), it could automatically generate and submit standardized compliance reports to regional Data Protection Authorities (DPAs), shifting enforcement from a passive to a proactive model.
- **Global Privacy Control (GPC) Integration:** Future versions should integrate support for emerging automated consent protocols, such as the Global Privacy Control signal (World Wide Web Consortium, 2026), allowing the extension to automatically reject tracking at the browser-header level before CMPs are even loaded.

6.4 Final Concluding Remarks

The enactment of the GDPR was a monumental step forward for digital human rights, establishing a robust theoretical framework for data protection. However, legislation alone is insufficient when applied to an ecosystem driven by the hyper-commodification of personal data. As corporations deploy increasingly sophisticated Dark Patterns and evasive tracking architectures to simulate compliance, the burden of enforcement cannot rest solely on reactive regulatory bodies or overwhelmed end-users.

This research highlights a critical paradigm shift required in the field of privacy engineering. To effectively counter compliance theatre, users must be equipped with localized, automated auditing tools. By bridging the gap between legal theory and software engineering, applications like the one developed in this thesis represent the necessary evolution of digital self-defence, ensuring that "Privacy by Default" transitions from a legal ideal into a verifiable technical reality.

References

- Adhikari, A., Das, S. & Dewri, R., 2025. Natural Language Processing of Privacy Policies: A Survey. *arXiv preprint*, pp. 1-27.
- Al-Rousan, T., Al-Shargabi, B. & Abualese, H., 2019. A New Security Model for Web Browser Local. *International Journal of Advanced Computer Science and Applications*, 10(8), p. 227–233.
- Barth, A., 2011. The HTTP state management mechanism, RFC 6265. *Internet Engineering Task Force (IETF)*.
- Castro, M., 2021. Understanding and Using Web Workers. *CODE Magazine*, January/February.
- Englehardt, S. & Narayanan, A., 2016. *Online Tracking: A 1-million-site Measurement and Analysis*. New York, Association for Computing Machinery, pp. 1388-1401.
- European Parliament and Council of the European Union, 2002. Directive 2002/58/EC of the European Parliament and of the Council of 12 July 2002 concerning the processing of personal data and the protection of privacy in the electronic communications sector (Directive on privacy and electronic communications). *Official Journal of the European Union*, pp. 37-44.
- European Parliament and Council of the European Union, 2016. Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC. *Official Journal of the European Union*, pp. 1-88.
- Google, 2026. *Migrate to Manifest V3*. [Online] Available at: <https://developer.chrome.com/docs/extensions/develop/migrate>
- Gray, C. M. et al., 2018. *The Dark (Patterns) Side of UX Design*. Montreal, s.n., pp. 1-14.
- Klonick, K., 2025. BAN COOKIE BANNERS: A CASE STUDY IN TECH. *Harvard Journal of Law & Technology*, 39(1), pp. 1-37.
- Kocyigit, E., Rossi, A. & Lenzini, G., 2023. Towards Assessing Features of Dark Patterns in Cookie Consent Processes. In: *Privacy and Identity Management*. s.l.:s.n., pp. 165-183.
- Ling, Y. et al., 2022. *Are they Toeing the Line? Diagnosing Privacy Compliance Violations among Browser Extension*. Rochester, s.n., pp. 1-12.
- Matte, C., Bielova, N. & Santos, C., 2020. *Do Cookie Banners Respect my Choice? : Measuring Legal Compliance of Banners from IAB Europe's Transparency and Consent Framework*. San Francisco, s.n., pp. 767-781.
- Mowery, K. & Shacham, H., 2012. Pixel Perfect: Fingerprinting Canvas in HTML5. *Proceedings of the Web 2.0 Security and Privacy Workshop*.
- Nouwens, M. et al., 2020. *Dark Patterns after the GDPR: Scraping Consent Pop-ups and Demonstrating their Influence*. Honolulu HI USA, s.n., pp. 1-13.
- Rodriguez, J. D. & Posegga, J., 2018. *CSP & Co. Can Save Us from a Rogue Cross-Origin Storage Browser Network! But for How Long?*. Tempe AZ USA, s.n., pp. 170-172.
- Sanchez-Rola, I., Santos, I. & Balzarotti, D., 2017. *Extension Breakdown: Security Analysis of Browsers Extension Resources Control Policies*. Vancouver, BC, Canada, s.n., pp. 1-17.

- Soe, T. H., Nordberg, O. E., Guribye, F. & Slavkovik, M., 2020. *Circumvention by design - dark patterns in cookie consent for online news outlets*. Tallinn, Estonia, s.n., pp. 1-12.
- Trevisan, M., Traverso, S., Bassi, E. & Mellia, M., 2019. 4 Years of EU Cookie Law: Results and Lessons Learned. *PROCEEDINGS ON PRIVACY ENHANCING TECHNOLOGIES*, 2019(2), pp. 126-145.
- Urban, T., Degeling, M., Holz, T. & Pohlmann, N., 2020. *Beyond the Front Page: Measuring Third Party Dynamics in the Field*. Taipei, Taiwan, Association for Computing Machinery, pp. 1275-1286.
- Utz, C. et al., 2019. *(Un)informed Consent: Studying GDPR Consent Notices in the Field*. New York, Association for Computer Machinery, pp. 973-990.
- Veale, M. & Zuiderveen Borgesius, F., 2022. Adtech and Real-Time Bidding under European Data Protection Law. *German Law Journal*, 23(2), p. 226–256.
- Wilson, S. et al., 2016. *The Creation and Analysis of a Website Privacy Policy Corpus*. Berlin, Germany, Association for Computational Linguistics, pp. 1330-1340.
- World Wide Web Consortium, 2016. *Web storage (Second Edition)*, s.l.: W3C Recommendation.
- World Wide Web Consortium, 2026. *Global Privacy Control (GPC)*. [Online] Available at: <https://www.w3.org/TR/gpc/>
- Zaeem, R. N. et al., 2020. *PrivacyCheck v2: A Tool that Recaps Privacy Policies for You*. Virtual Event Ireland, s.n., pp. 3441-3444.

Appendices

Appendix: Core Application Code Snippets

This appendix provides select source code snippets from the *Privacy Policy Analyzer & Cookie Trax* browser extension to demonstrate the underlying software engineering methodology and logical architecture. The application is built adhering to Google's Manifest V3 framework, utilizing vanilla JavaScript for localized, client-side execution to ensure strict data minimization.

Appendix 1. Contextual Natural Language Processing (NLP) via Web Workers

The following snippet from `analyzer-worker.js` demonstrates the asynchronous text parsing engine. It utilizes a Web Worker to prevent UI thread blocking and applies contextual awareness by scanning for negation keywords before applying a risk penalty to the privacy score.

```
/**
 * Privacy Policy Analyzer - Web Worker
 * Runs analysis in background thread to keep UI responsive
 * Handles large policies with chunked processing
 */

// Try to import the analyzer functions
try {
  importScripts('analyzer.js');
  console.log('[Worker] analyzer.js loaded successfully');
} catch (error) {
  console.error('[Worker] Failed to load analyzer.js:', error);
  self.postMessage({
    success: false,
    error: 'Failed to load analyzer.js: ' + error.message
  });
}

// Listen for messages from main thread (popup.js)
self.onmessage = async (event) => {
  const { id, text, action } = event.data;

  console.log(`[Worker] Received message - ID: ${id}, Action: ${action}, Text length: ${text ? text.length : 0}`);

  try {
    if (action === 'analyze') {
      // Verify analyzer function exists
      if (typeof analyzePrivacyPolicy !== 'function') {
        throw new Error('analyzePrivacyPolicy function not found');
      }

      // If text is very large, process in chunks
      if (text.length > 100000) {
```

```

        console.log('[Worker] Large text detected, processing in
chunks...');
        const results = await analyzeInChunks(text);
        self.postMessage({
            id,
            success: true,
            result: results,
            mode: 'chunked'
        });
    } else {
        // Small text - analyze directly
        console.log('[Worker] Analyzing text directly...');
        const result = analyzePrivacyPolicy(text);
        self.postMessage({
            id,
            success: true,
            result,
            mode: 'direct'
        });
    }
} else {
    self.postMessage({
        id,
        success: false,
        error: 'Unknown action: ' + action
    });
}
} catch (error) {
    console.error('[Worker] Error:', error);
    self.postMessage({
        id,
        success: false,
        error: error.message
    });
}
};

/**
 * Analyze large text in chunks to prevent timeout
 * @param {string} text
 * @returns {object} Merged analysis result
 */
async function analyzeInChunks(text) {
    const CHUNK_SIZE = 50000;
    const chunks = chunkText(text, CHUNK_SIZE);

    console.log(`[Worker] Processing ${chunks.length} chunks...`);

    let processedChunks = 0;

```

```

const chunkResults = chunks.map((chunk, index) => {
  const result = analyzePrivacyPolicy(chunk.chunk);
  processedChunks++;

  // Send progress update every 5 chunks
  if (processedChunks % 5 === 0) {
    self.postMessage({
      type: 'progress',
      processed: processedChunks,
      total: chunks.length,
      percentage: Math.round((processedChunks / chunks.length) * 100)
    });
    console.log(`[Worker] Progress: ${processedChunks}/${chunks.length}`);
  }

  return result;
});

console.log('[Worker] Merging chunk results...');

return chunkResults.length > 0 ? chunkResults[0] : { score: 0, metrics: {} };
}

```

Appendix 2. Dynamic Cookie Auditing and Discrepancy Engine

The following snippet from `cookie-analyzer.js` illustrates the real-time DOM auditing module. It leverages the Chrome Cookies API to extract the live tracking payload and cross-references it with the established NLP score to detect "compliance theatre".

```

static assessRisk(categorized, consentStatus, bannerActive = false,
previousAnalysis = null, userRejected = false) {
  let riskScore = 0;
  let riskLevel = 'LOW';
  let complianceStatus = 'COMPLIANT';
  let explanation = '';
  const hasTrackingCookies = categorized.tracking.length > 0 ||
    categorized.analytics.length > 0 ||
    categorized.advertising.length > 0 ||
    categorized.social.length > 0;
  if (hasTrackingCookies && bannerActive && consentStatus.found &&
consentStatus.accepted === null) {
    const count = categorized.tracking.length +
categorized.analytics.length +
    categorized.advertising.length +
categorized.social.length;
    riskLevel = 'HIGH';
    complianceStatus = 'NON-COMPLIANT';
    explanation = `Pre-consent tracking detected: ${count} tracking/social
cookies are active while the consent banner is still showing. The consent cookie

```

```

('${consentStatus.cookieName}') was found but its value could not be verified –
this violates GDPR.`;
    }
else if (hasTrackingCookies && userRejected && consentStatus.found &&
consentStatus.accepted === true) {
    riskLevel = 'HIGH';
    complianceStatus = 'NON-COMPLIANT';
    const count = categorized.tracking.length +
categorized.analytics.length + categorized.advertising.length;
    explanation = `Consent choice not honored: You clicked reject but
${count} tracking cookies remain active and the consent cookie is still set to
"accepted" – your rejection was ignored. This violates GDPR.`;
    }
else if (hasTrackingCookies && userRejected && !bannerActive) {
    const count = categorized.tracking.length +
categorized.analytics.length +
categorized.advertising.length +
categorized.social.length;
    riskLevel = 'HIGH';
    complianceStatus = 'OPT-OUT IGNORED';
    explanation = `Tracking continues after rejection: You declined cookies
but ${count} tracking/social cookies are still active. The site does not honor opt-
out choices – this violates GDPR Article 7.`;
    }
return { score: normalizedScore, level: riskLevel, complianceStatus, explanation };
}

```